MikroTik Certified Security Engineer (MTCSE)

https://wiki.mikrotik.com/wiki/Manual:Securing_Your_Router

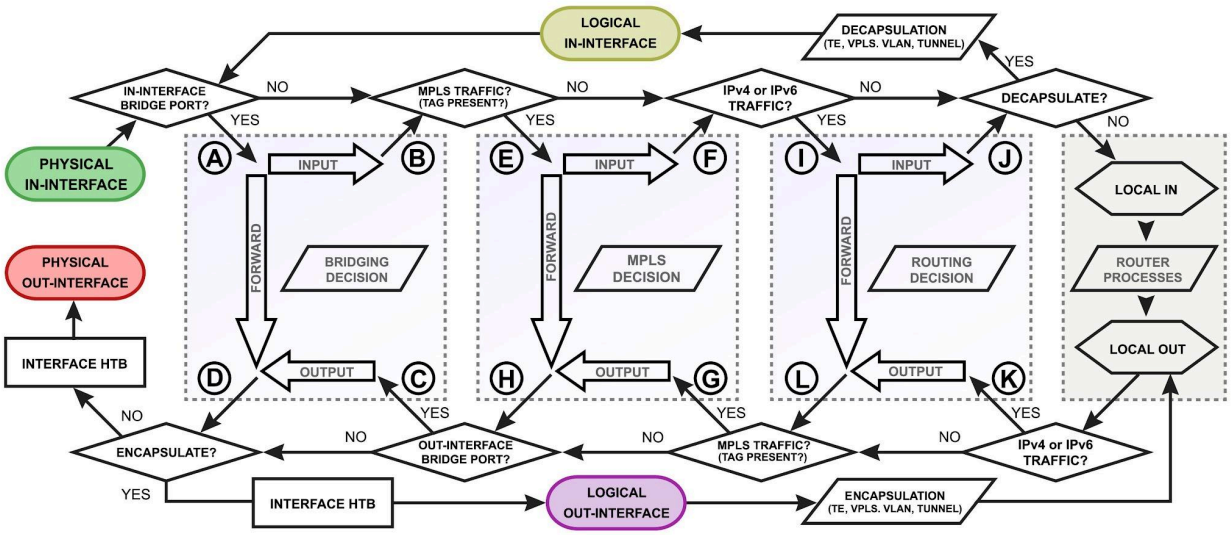
Attacks, mechanisms and services
Security Attacks
Interruption: This is an attack on availability
Interception: This is an attack on confidentiality
Modification: This is an attack on integrity
Fabrication: This is an attack on authenticity

Security Services
Confidentiality (privacy)
Authentication (who created or sent the data)
Integrity (has not been altered)
Non-repudiation (the order is final)
Access control (prevent misuse of resources)
Availability (permanence, non-erasure)
Denial of Service Attacks
Virus that deletes files

The most common threats
Virus
Worn
Trojan horse
Spyware
Ransomeware
DoS and DDoS
Phishing
SQL Injection

RouterOS security deployment
Upgrade to Patched Version
Protect all services
Unused port disable

Packet flow
How the packet are forwarding



firewall chains

here are three predefined chains, which cannot be deleted:

input - used to process packets entering the router through one of the interfaces with the destination IP address which is one of the router's addresses. Packets passing through the router are not processed against the rules of the input chain
forward - used to process packets passing through the router
output - used to process packets originated from the router and leaving it through one of the interfaces. Packets passing through the router are not processed against the rules of the output chain

Stateful firewall
Stateful Filtering
MikroTik RouterOS Firewall is based on Stateful Filterig technology that can be used to detect and block many stealth scans, DoS attacks, SYN floods. Network communication is made up of small chunks of data called packets, and several

of these packets are used solely to create, maintain, and finish the connection. The MikroTik RouterOS Stateful Firewall keeps in memory informtion on each connection passing through it. When a foreign packet tries to enter the network, claiming to be part of an existing connection, the firewall consults it's list of connections. When it finds that the packet doesn't match any of these, it can drop that packet and defeat the scan!

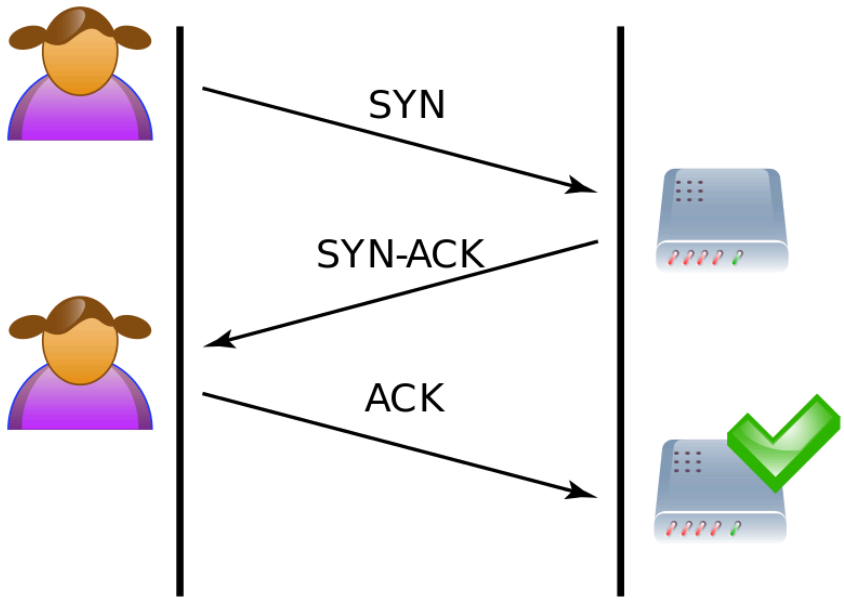
RAW table

Firewall RAW table allows to selectively bypass or drop packets before connection tracking that way significantly reducing load on CPU. Tool is very useful for DOS attack mitigation.
There are two predefined chains in RAW tables:

prerouting - used to process any packet entering the router
output - used to process packets originated from the router and leaving it through one of the interfaces. Packets passing through the router are not processed against the rules of the output chain

SYN flood mitigation using RAW table

A SYN flood is a form of denial-of-service attack in which an attacker sends a succession of SYN requests to a target's system in an attempt to consume enough server resources to make the system unresponsive to legitimate traffic.[1][2] SYN flood is a protocol attack



RouterOS default configuration

Every router is factory pre-configured with the IP address 192.168.88.1/24 on the ether1 port. The default username is admin with no password. After you log in for the first time, please create a new user with a password in the "full" group, re-login and delete the default admin user.

Best practices for management access
Access to a router
Access by IP address
Router services
RouterOS MAC-access
Neighbor Discovery

Detecting an attack to critical infrastructure services
IDS implementation
PING FLOOD- new firewall rule-log action
Port knocking - input ICMP rule
Port scan detect- firewall rule tarpit
Broute force detect and drop- Destination limit

Bridge filter
Bridge VLAN Filtering since RouterOS v6.41 provides VLAN aware Layer2 forwarding and VLAN tag modifications within the bridge. This set of features makes bridge operation more like a traditional Ethernet switch and allows to overcome Spanning Tree compatibilty issues compared to configuration when tunnel-like VLAN interfaces are bridged. Bridge VLAN Filtering configuration is highly recommended to comply with STP (IEEE 802.1D), RSTP (IEEE 802.1W) standards and is mandatory to enable MSTP (IEEE 802.1s) support in RouterOS.

The main VLAN setting is vlan-filtering which globally controls vlan-awareness and VLAN tag processing in the bridge. If vlan-filtering=no, bridge ignores VLAN tags, works in a shared-VLAN-learning (SVL) mode and cannot modify VLAN tags of packets. Turning on vlan-filtering enables all bridge VLAN related functionality and independent-VLAN-learning (IVL) mode. Besides joining the ports for Layer2 forwarding, bridge itself is also an interface therefore it has Port VLAN ID (pvid).

There are two bridge firewall tables:
filter - bridge firewall with three predefined chains:
input - filters packets, where the destination is the bridge (including those packets that will be routed, as they are destined to the bridge MAC address anyway)
output - filters packets, which come from the bridge (including those packets that has been routed normally)
forward - filters packets, which are to be bridged (note: this chain is not applied to the packets that should be routed through the router, just to those that are traversing between the ports of the same bridge)

nat - bridge network address translation provides ways for changing source/destination MAC addresses of the packets traversing a bridge. Has two built-in chains:
srcnat - used for "hiding" a host or a network behind a different MAC address. This chain is applied to the packets leaving the router through a bridged interface
dstnat - used for redirecting some packets to other destinations

Advanced options in firewall filter
/ipv6 firewall raw
/ipv6 firewall address-list
/ipv6 firewall filter
/interface list

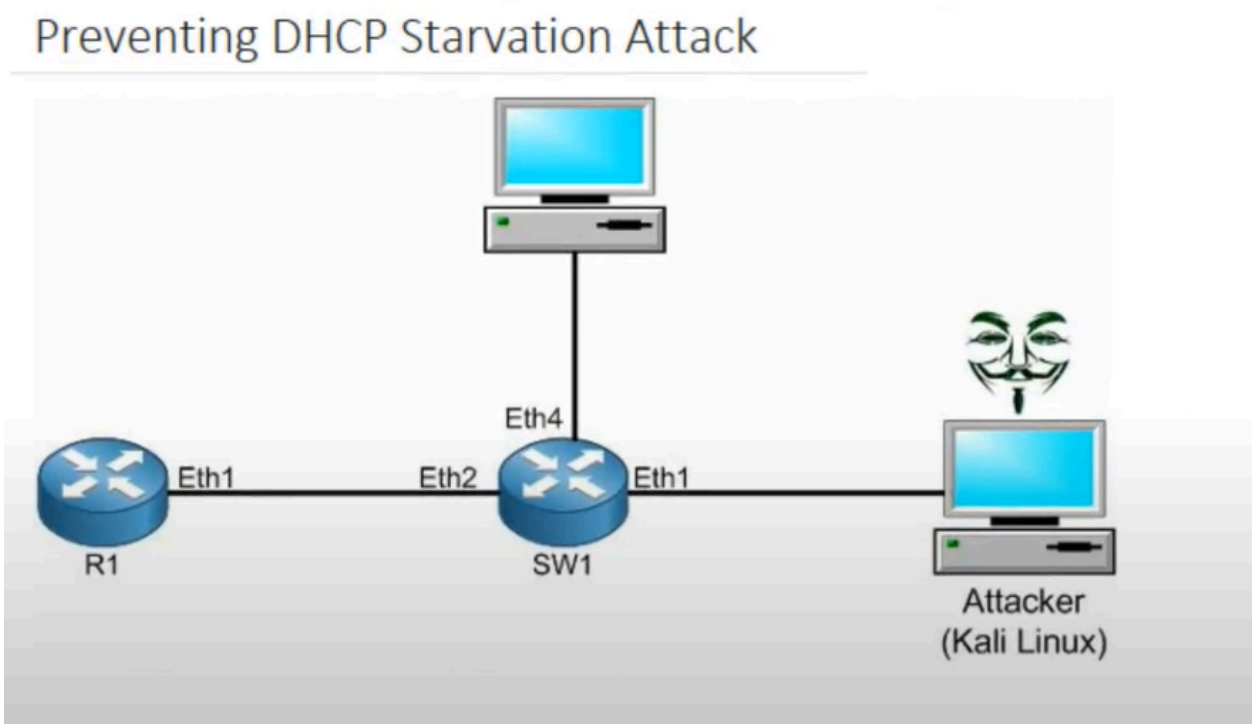
icmp filtering
Ping block-input chain

MNDP attacks and prevention
MikroTik Neighbor Discovery protocol (MNDP) and LLDP allows to "find" other devices compatible with MNDP or CDP (Cisco Discovery Protocol) or LLDP in Layer2 broadcast domain.
/ip neighbor discovery-settings

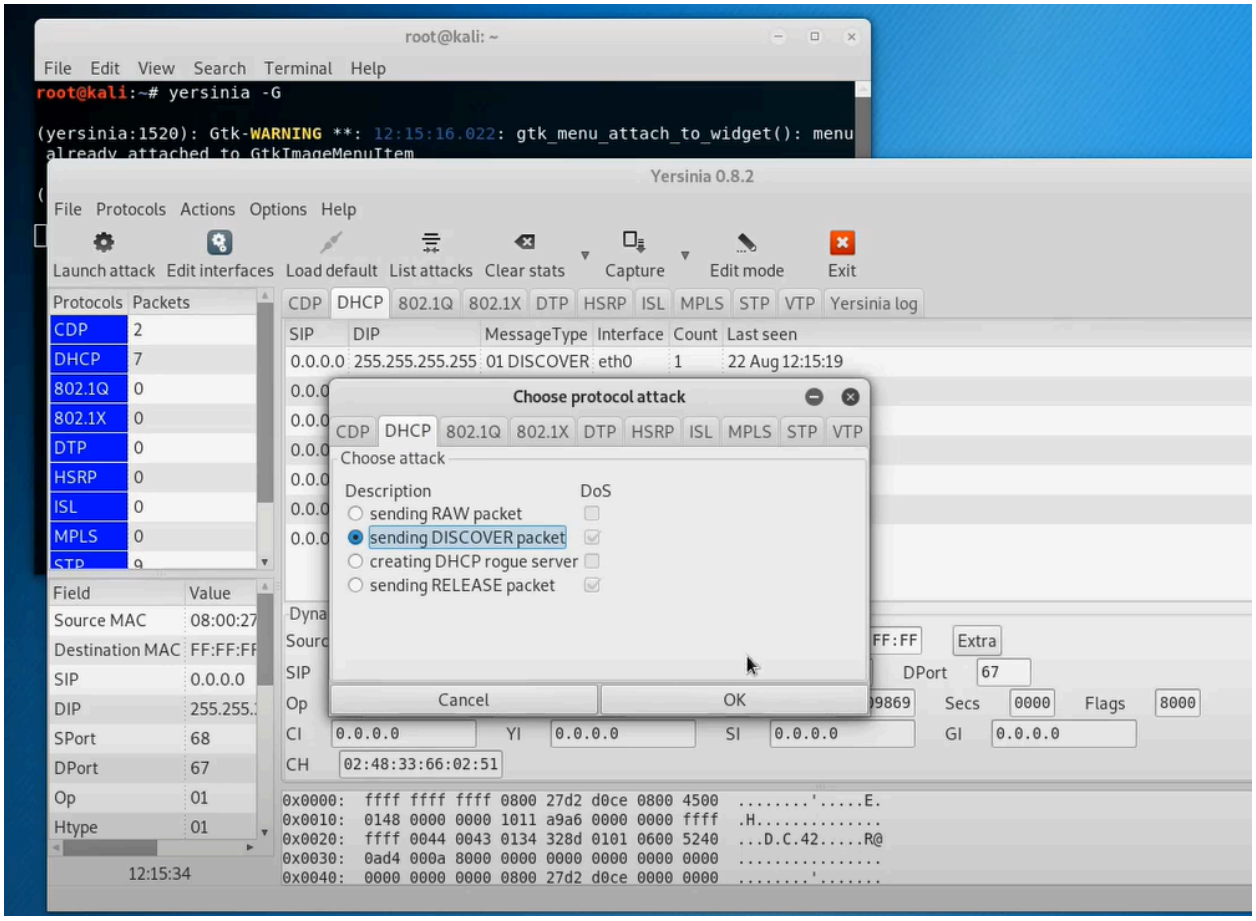
DHCP: rogue servers, starvation attacks and prevention

DHCP starvation attack

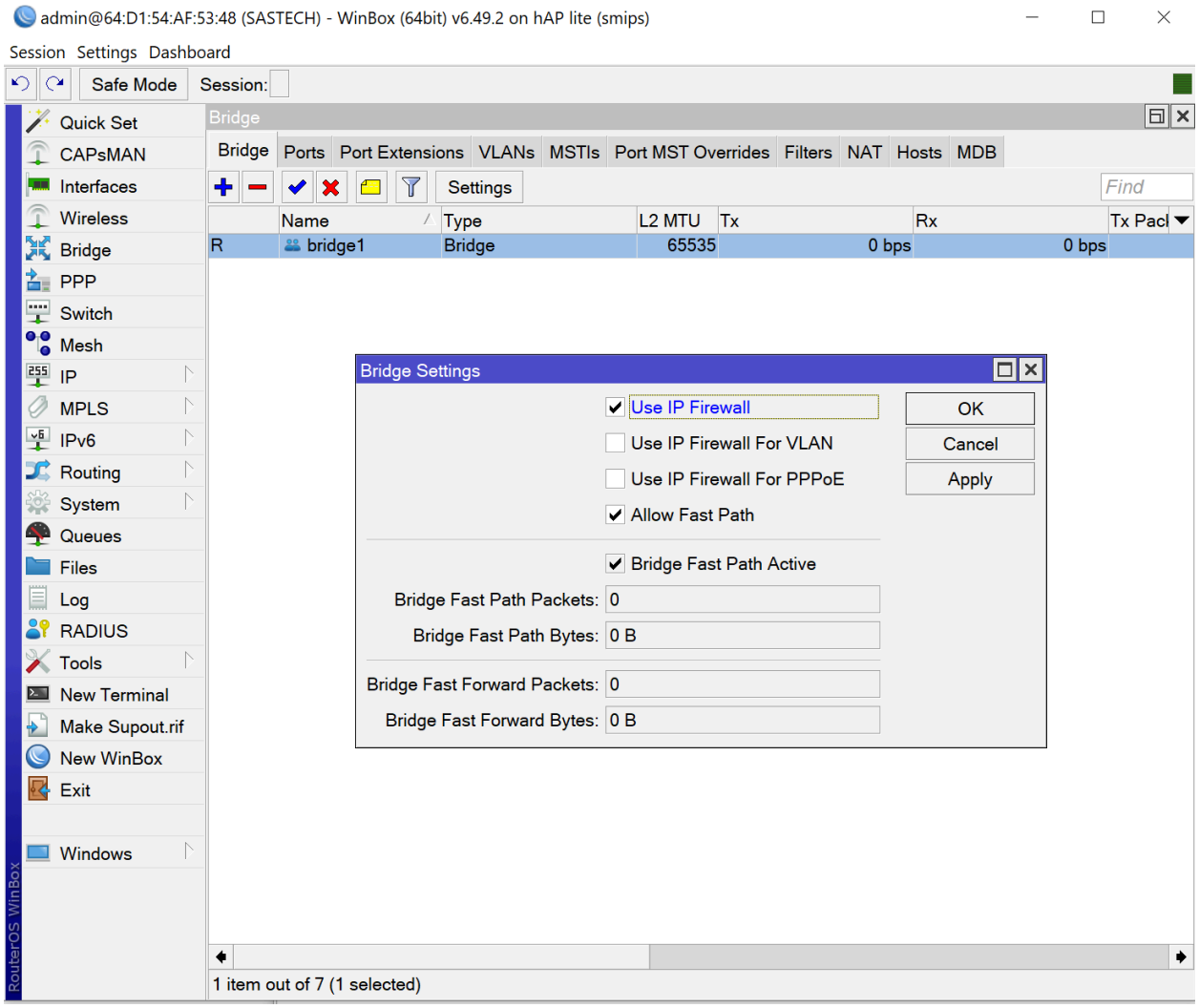
Configure DHCP server and Kali linux

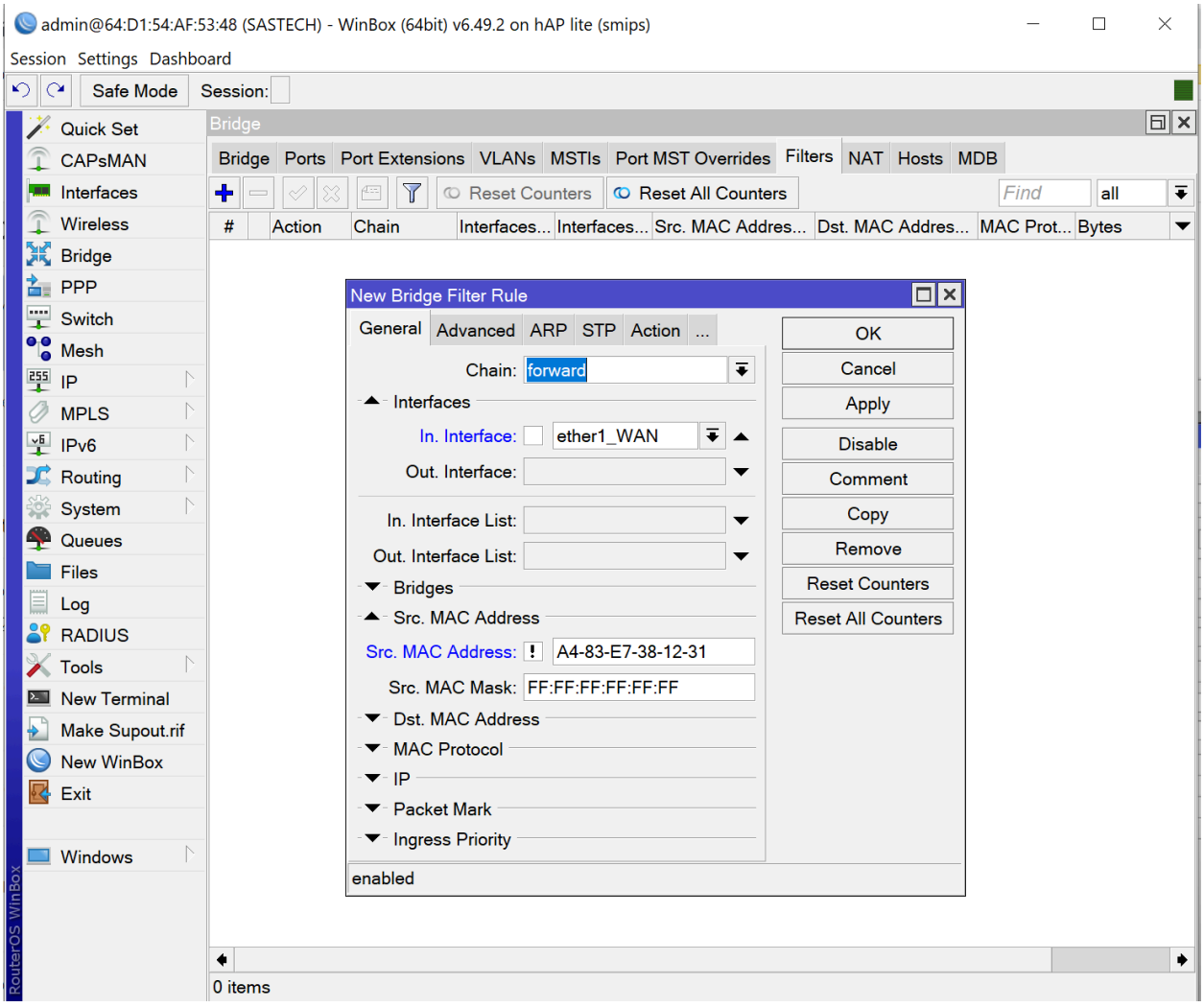

Preventing DHCP Starvation Attack
Eth4
Eth1
Eth2
Eth1
R1
SW1
Attacker
(Kali Linux)

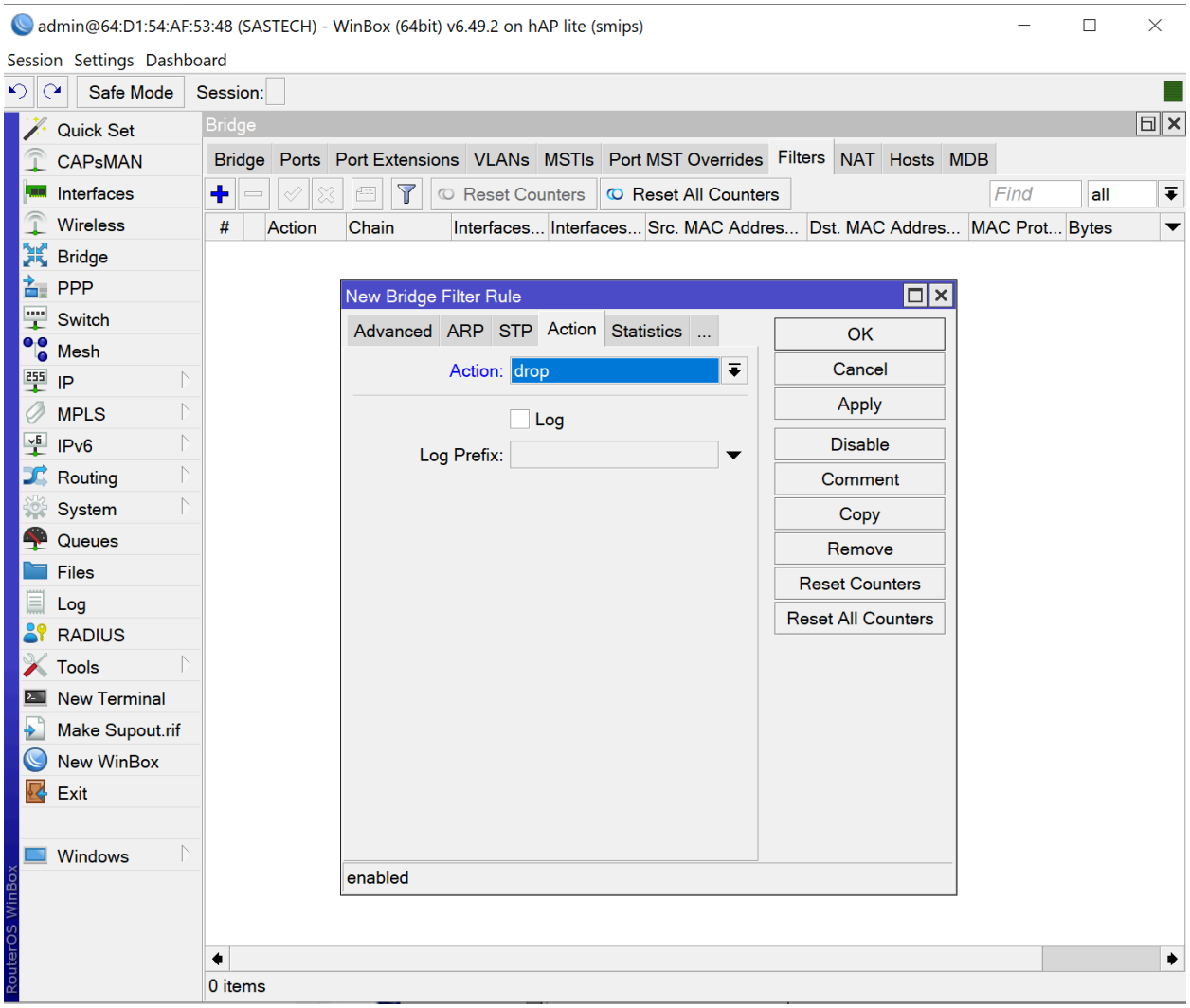
Attack



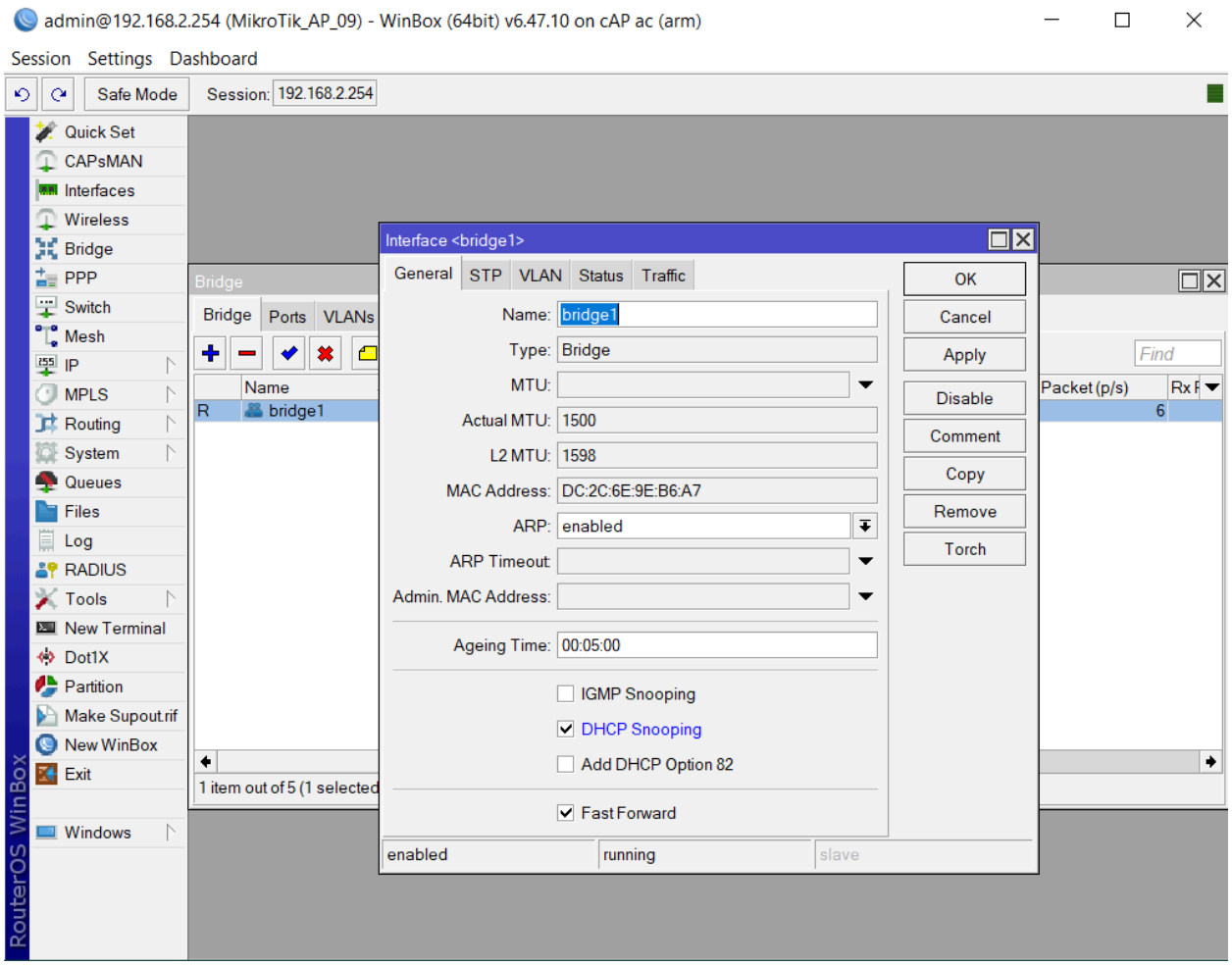
Preventing attack


admin@64:D1:54:AF:53:48 (SASTECH) - WinBox (64bit) v6.49.2 on hAP lite (smips)
Session Settings Dashboard
Safe Mode
Session:
Quick Set
CAPsMAN
Interfaces
Wireless
Bridge
PPP
Switch
Mesh
IP
MPLS
IPv6
Routing
System
Queues
Files
Log
RADIUS
Tools
New Terminal
Make Supout.rif
New WinBox
Exit
Windows
RouterOS WinBox
Bridge
Bridge
Ports
Port Extensions
VLANs
MSTIs
Port MST Overrides
Filters
NAT
Hosts
MDB
Settings
Find
Name
Type
L2 MTU
Tx
Rx
R
bridge1
Bridge
65535
0 bps
0 bps
Bridge Settings
Use IP Firewall
Use IP Firewall For VLAN
Use IP Firewall For PPPoE
Allow Fast Path
Bridge Fast Path Active
Bridge Fast Path Packets:
0
Bridge Fast Path Bytes:
0 B
Bridge Fast Forward Packets:
0
Bridge Fast Forward Bytes:
0 B
OK
Cancel
Apply
1 item out of 7 (1 selected)

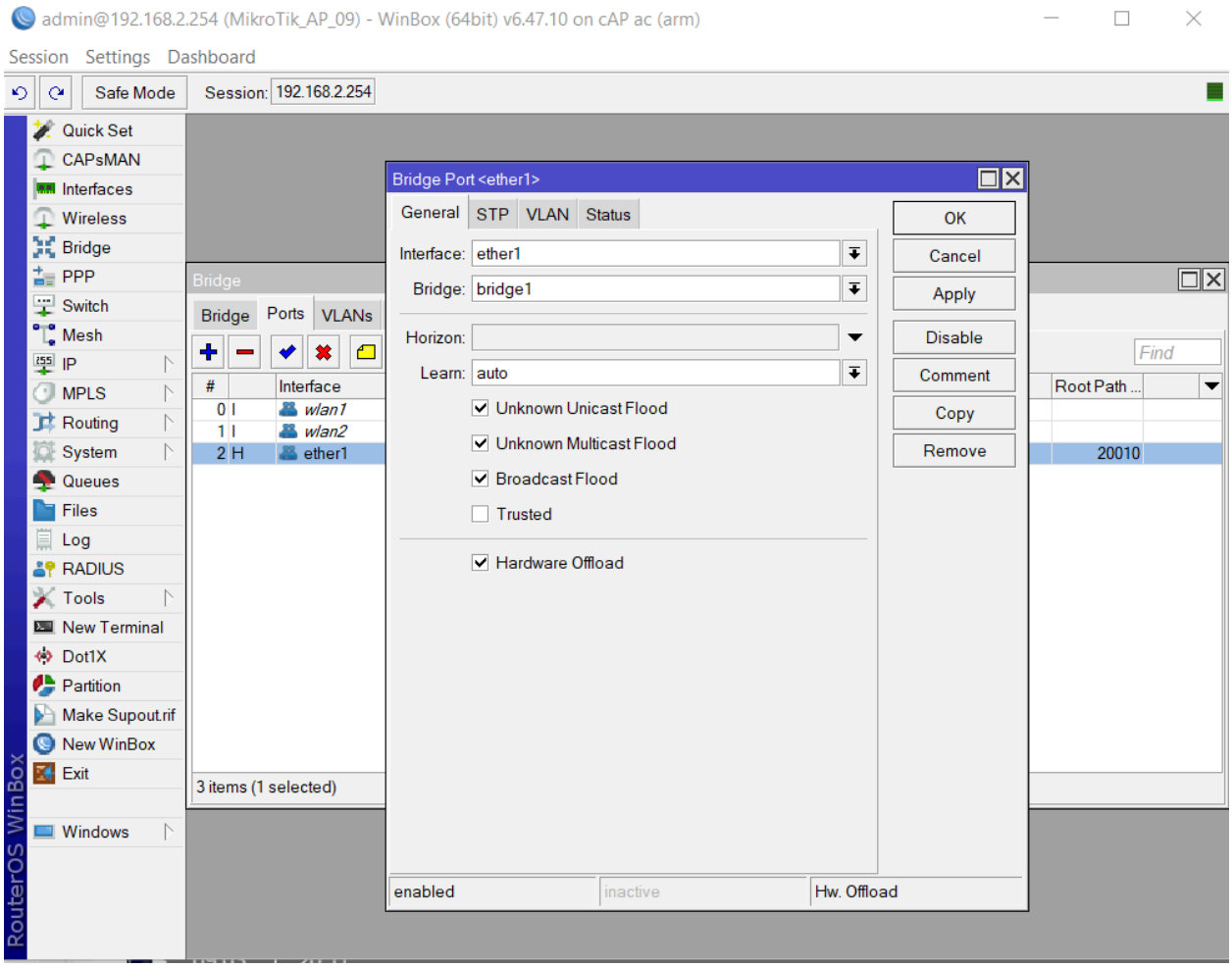

admin@64:D1:54:AF:53:48 (SASTECH) - WinBox (64bit) v6.49.2 on hAP lite (smips)
Session Settings Dashboard
Safe Mode
Session:
Quick Set
CAPsMAN
Interfaces
Wireless
Bridge
PPP
Switch
Mesh
IP
MPLS
IPv6
Routing
System
Queues
Files
Log
RADIUS
Tools
New Terminal
Make Supout.rif
New WinBox
Exit
Windows
RouterOS WinBox
Bridge
Bridge Ports Port Extensions VLANs MSTIs Port MST Overrides Filters NAT Hosts MDB
Reset Counters
Reset All Counters
Find
all
Action Chain Interfaces... Interfaces... Src. MAC Addres... Dst. MAC Addres... MAC Prot... Bytes
New Bridge Filter Rule
General Advanced ARP STP Action ...
Chain: forward
Interfaces
In. Interface: ether1_WAN
Out. Interface:
In. Interface List:
Out. Interface List:
Bridges
Src. MAC Address
Src. MAC Address: A4-83-E7-38-12-31
Src. MAC Mask: FF:FF:FF:FF:FF:FF
Dst. MAC Address
MAC Protocol
IP
Packet Mark
Ingress Priority
OK
Cancel
Apply
Disable
Comment
Copy
Remove
Reset Counters
Reset All Counters
enabled
0 items



DHCP snooping (prevent unauthorized or rogue DHCP)



Enable trusted port



IP>DHCP>Alert
Script
/tool email send
to="admin@example.com "
subject="$[/system identify get name]-
Rouge DHCP Server Identified $[/system clock get time]"|

TCP SYN attacks and prevention
/ip settings set tcp-syncookies=yes
/ip firewall connection tracking set tcp-syncookie=yes

UDP attacks and prevention
DDOS attack using UDP
/ip firewall raw
add chain=prerouting in-interface=WAN action=drop

protocol=udp dst-port=53 comment=“DNS
Amplification”

ICMP Smurf attacks and prevention
Limit incoming connections

FTP, telnet and SSH brute-force attacks and prevention

To stop SSH/FTP attacks on your router, follow this advice.

This configuration allows only 10 FTP login incorrect answers per minute

in /ip firewall filter

add chain=input protocol=tcp dst-port=21 src-address-list=ftp_blacklist action=drop \
comment="drop ftp brute forcers"

add chain=output action=accept protocol=tcp content="530 Login incorrect" \
dst-limit=1/1m,9,dst-address/1m

add chain=output action=add-dst-to-address-list protocol=tcp content="530 Login incorrect" \
address-list=ftp_blacklist address-list-timeout=3h

SSH
This will prevent a SSH brute forcer to be banned for 10 days after repetitive attempts. Change the timeouts as necessary.

in /ip firewall filter

add chain=input protocol=tcp dst-port=22 src-address-list=ssh_blacklist action=drop \
comment="drop ssh brute forcers" disabled=no

add chain=input protocol=tcp dst-port=22 connection-state=new \
src-address-list=ssh_stage3 action=add-src-to-address-list address-list=ssh_blacklist \
address-list-timeout=10d comment="" disabled=no

add chain=input protocol=tcp dst-port=22 connection-state=new \
src-address-list=ssh_stage2 action=add-src-to-address-list address-list=ssh_stage3 \
address-list-timeout=1m comment="" disabled=no

add chain=input protocol=tcp dst-port=22 connection-state=new src-address-list=ssh_stage1 \

action=add-src-to-address-list address-list=ssh_stage2 address-list-timeout=1m comment="" disabled=no

add chain=input protocol=tcp dst-port=22 connection-state=new action=add-src-to-address-list \
address-list=ssh_stage1 address-list-timeout=1m comment="" disabled=no

Port scan detection and prevention
To protect the Router from port scanners, we can record the IPs of hackers who try to scan your box. Using this address list we can drop connection from those IP

in /ip firewall filter

add chain=input protocol=tcp psd=21,3s,3,1 action=add-src-to-address-list address-list="port scanners" address-list-timeout=2w comment="Port scanners to list " disabled=no
Various combinations of TCP flags can also indicate port scanner activity.

add chain=input protocol=tcp tcp-flags=fin,!syn,!rst,!psh,!ack,!urg action=add-src-to-address-list address-list="port scanners" address-list-timeout=2w comment="NMAP FIN Stealth scan"

Introduction to cryptography and terminology
Cryptography is the science of using mathematics to encrypt and decrypt data.
Check CEH cryptography lecture

Encryption methods
The 4 common encryption methods
There are different encryption methods based on the type of keys used, key length, and size of data blocks encrypted. Here we discuss some of the common encryption methods.

1. Advanced Encryption Standard (AES)
Advanced Encryption Standard is a symmetric encryption algorithm that encrypts fixed blocks of data (of 128 bits) at a time. The keys used to decipher the text can be 128-, 192-, or 256-bit long. The 256-bit key encrypts the data in 14 rounds, the 192-bit key in 12 rounds, and the 128-bit key in 10 rounds. Each round consists of several steps of substitution, transposition, mixing of plaintext, and more. AES encryption standards are the most commonly used encryption methods today, both for data at rest and data in transit.

2. Rivest-Shamir-Adleman (RSA)
Rivest-Shamir-Adleman is an asymmetric encryption algorithm that is based on the factorization of the product of two large prime numbers. Only someone with the knowledge of these numbers will be able to decode the message successfully. RSA is often used in digital signatures but works slower when large volumes of data need to be encrypted.

3. Triple Data Encryption Standard (TripleDES)

Triple Data Encryption Standard is a symmetric encryption and an advanced form of the DES method that encrypts blocks of data using a 56-bit key. TripleDES applies the DES cipher algorithm three times to each data block. TripleDES is commonly used to encrypt ATM PINs and UNIX passwords.

4. Twofish
Twofish is a license-free encryption method that ciphers data blocks of 128 bits. It's considered the successor to the Blowfish encryption method that ciphered message blocks of 64 bits. Twofish always encrypts data in 16 rounds regardless of the key size. Though it works slower than AES, the Twofish encryption method continues to be used by many file and folder encryption software solutions.

Algorithms - symmetric, asymmetric
Check CEH cryptography lecture

Public key infrastructure (PKI)
Check CEH cryptography lecture

Certificates
System>Certificates

Make certificate templates
/certificate
add name=ca-template common-name=myCa key-usage=key-cert-sign,crl-sign
add name=server-template common-name=server
add name=client1-template common-name=client1
add name=client2-template common-name=client2

Sign certificates and add CRL url. We will use IP address of the server as CRL URL.
/certificate
sign ca-template ca-crl-host=10.5.101.16 name=myCa
sign server-template ca=myCa name=server
sign client1-template ca=myCa name=client1
sign client2-template ca=myCa name=client2

If certificate does not have T flag then you need to set it as trusted before using it:
/certificate
set myCa trusted=yes
set server trusted=yes

Export client certificates with keys and CA certificate
/certificate export-certificate myCa
/certificate export-certificate client1 export-passphrase=xxxxxxxx

/certificate export-certificate client2 export-passphrase=xxxxxxxx

Port knocking
Port knocking is a method of externally opening ports on a firewall by generating a connection attempt on a set of prespecified series of closed ports

Port knocking is a method that enables access to the router only after receiving a sequenced connection attempts on a set of prespecified closed ports. Once the correct sequence of the connection attempts is received, the RouterOS dynamically adds a host source IP to the allowed address list and You will be able to connect your router.

This example demonstrates how to set your router to use port knocking method:

The First firewall rule will store all source ip's which makes connection to router with tcp protocol on port 9000.

```
/ip firewall filter
add action=add-src-to-address-list address-list="port:9000" \
    address-list-timeout=1m chain=input dst-port=9000 protocol=tcp
```
Second rule adds the source ip to "secure" address list only if a host has the same ip address, stored by first firewall rule, and knocks on tcp port 6000.

```
add action=add-src-to-address-list address-list="secure" address-list-timeout=1m \
 chain=input dst-port=6000 protocol=tcp src-address-list="port:9000"
```
The third rule is created to accept all connections to the router from "secure" host.

```
add chain=input src-address-list=secure action=accept
```
Everything else is dropped by this rule.

```
add action=drop chain=input
```

Secure connections (HTTPS, SSH, WinBox)
IP>services

Default ports for the services
IP>Services

Tunneling through SSH
Putty
```
/ip ssh
set forwarding-enabled=yes
```

Introduction to IPsec
IPSec is a widely used protocol suite for establishing VPN tunnel. IPSec is not a single protocol, but a suite of protocols for securing IP communications.

L2TP + IPsec
CHeck L2TP lecture sheet

SSTP with certificates
Check SSTP lecture sheet